Module: authentication and sessions

English version of ../../modules/auth.md.

Files: app/security.py (rules), app/routers/auth.py (HTTP), app/models.py (contract).

1. Purpose and boundaries

Sign-up, sign-in, session cookies, role checks, admin sign-in with an access code. It does **not** manage requests (that is the quiz) and does not send e-mail.

2. Use scenarios

- Sign-up with phone, nickname and password → session cookie valid for 7 days.
- Sign-in of an existing user; sign-out removes the session row.
- Phone availability check before sign-up.
- Admin sign-in with the code from the environment; the route answers 503 when the code is not configured.
- Rejections: duplicate phone or nickname → 409; weak password → 400.

3. Contract

/api/auth/{check-phone, register, login, admin-login, logout, current-user, users}. Models are Pydantic (LoginRequest, RegisterRequest, AdminLoginRequest).

4. Data

Writes users and sessions. Passwords are stored hashed only; sessions are bound to a user.

5. Access rules

Role user by default; admin only through admin sign-in with the code from ADMIN_CODE (constant-time comparison). The user list endpoint exposes no password hashes.

6. Dependencies

Outgoing: SQLite, hashlib/secrets. Incoming: pages /, /admin, everything under /api/*.

7. Configuration

ADMIN_CODE (required for admin sign-in), DB_PATH, CORS_ORIGINS.

8. Build and debug

```
make test
python -m pytest tests/test_auth.py tests/test_security.py -q
```

9. Tests

`tests/test_auth.py`: sign-up → session, current user, duplicate (409), weak password (400), sign-out, admin sign-in with a wrong code (401) and the right one (200). `tests/test_security.py`: no hard-coded password, no wildcard CORS with credentials, admin code comes from the environment, keep-alive is opt-in.

10. Observability

Failures are visible as HTTP codes; the sign-in path prints nothing sensitive.

11. Limitations and readiness

- `hash_password` is unsalted SHA-256 kept for compatibility with existing accounts; a new project must use `argon2`/`bcrypt`.
- No rate limiting and no password reset flow.
- Readiness: covered by tests, no secret in code, fail-closed admin path.